

Bilaga 1 – MCFFS 2026:11: Säkerhetsåtgärder och ledningens utbildning

MCFFS 2026:11 är en av de mest centrala föreskrifterna för svenska verksamheter som omfattas av cybersäkerhetslagen (NIS2). Föreskriften konkretiserar vilka organisatoriska, tekniska, driftrelaterade och fysiska säkerhetsåtgärder verksamhetsutövare behöver arbeta med och reglerar även ledningens utbildning.

Föreskriften träder i kraft den **1 oktober 2026**.

Observera: Detta är en sammanfattande vägledning och ersätter inte föreskriften eller juridisk bedömning av vilka krav som gäller för en specifik verksamhet.

Vilka omfattas?

För de flesta väsentliga och viktiga verksamhetsutövare gäller föreskriften i sin helhet.

Det finns dock ett viktigt undantag. Verksamhetsutövare som **uteslutande** bedriver sektorsverksamhet inom följande områden omfattas endast av kraven på ledningens utbildning i 2 kap. 1 §:

- digital infrastruktur,
- digitala leverantörer,
- förvaltning av IKT-tjänster mellan företag,
- post- och budtjänster,
- rymden.

För dessa sektorer finns säkerhetskrav i EU:s genomförandeförordning respektive sektorsspecifika föreskrifter.

1. Ledningens utbildning

Ledningen ska ha den kunskap och kompetens som krävs för att kunna:

- fastställa mål och inriktning för cybersäkerheten,
- bedöma vilka säkerhetsåtgärder som behöver genomföras,
- förstå organisationens cyberrisker,
- samt övervaka genomförandet av säkerhetsåtgärder.

Utbildningen bör bland annat behandla ledningens roll, relevant reglering och terminologi, riskhantering, systematiskt cybersäkerhetsarbete och organisationens egna interna regler och arbetssätt.

Praktisk konsekvens: NIS2-utbildning för styrelse, VD eller motsvarande ledningsfunktion bör vara en dokumenterad del av organisationens compliance-program.

2. Systematiskt och riskbaserat cybersäkerhetsarbete

Organisationen ska bedriva cybersäkerhetsarbetet **systematiskt, riskbaserat och utifrån ett allriskperspektiv**.

Arbetet ska bland annat omfatta att:

1. identifiera externa krav, interna behov och risker,
2. utforma och införa säkerhetsåtgärder,
3. följa upp risker och säkerhetsåtgärder,
4. kontinuerligt förbättra säkerhetsåtgärderna.

Cybersäkerhetsarbetet ska dessutom integreras i organisationens befintliga styrning.

Föreskriften pekar ut **ISO/IEC 27001:2022 och ISO/IEC 27002:2022 eller motsvarande** som lämpliga standarder att använda som stöd.

3. Styrande dokument och evidens

Organisationen ska ha interna regler och arbetssätt som behövs för att genomföra lämpliga och proportionella säkerhetsåtgärder.

Det är också viktigt att kunna visa att reglerna faktiskt efterlevs.

Organisationen behöver därför identifiera vilken information som behöver dokumenteras och sparas för:

- uppföljning,
- utvärdering,
- tillsyn.

Detta kan exempelvis omfatta beslut, riskanalyser, åtgärdsplaner, genomförda kontroller och resultat från uppföljningar.

Praktisk konsekvens: NIS2-compliance handlar inte bara om att ha policydokument – organisationen behöver kunna presentera **evidens på faktisk efterlevnad**.

4. Roller och ansvar

Föreskriften ställer tydliga krav på ansvarsfördelning.

Organisationen ska bland annat utse:

- **samordnare** för cybersäkerhetsarbetet,
- **informationsägare** för informationsbehandling,
- **systemägare** för system.

Ledningen ska samtidigt säkerställa att organisationen har tillräckliga resurser och befogenheter för cybersäkerhetsarbetet.

Ledningen ska informeras om genomförandet av säkerhetsåtgärderna och organisationens cybersäkerhetsnivå **vid behov men minst en gång per år**.

5. Personalsäkerhet och utbildning

Organisationen behöver arbeta strukturerat med personalsäkerhet.

Det omfattar bland annat:

- kontroller vid rekrytering och anlitande,
- kontroller vid förändrad åtkomst,
- säkerhetsutbildning,
- säkerhetsövningar,
- informationsinsatser.

Utbildning bör anpassas efter personens roll, ansvar och befogenheter.

6. Omvärldsbevakning

Organisationen ska aktivt bevaka:

- cyberhot,
- sårbarheter,
- teknisk utveckling,
- förändrade rättsliga krav,
- tillgängligt stöd och rekommendationer.

Relevant information ska bland annat hämtas från leverantörer och NCSC.

Det innebär att strukturerad **Cyber Threat Intelligence och vulnerability intelligence** blir en naturlig del av compliance-arbetet.

7. Informationsklassning och riskhantering

Information ska klassificeras utifrån behovet av:

- konfidentialitet,
- riktighet och autenticitet,
- tillgänglighet.

Risker ska därefter identifieras, analyseras och värderas utifrån konsekvens och sannolikhet.

Organisationen ska även fastställa kriterier för **riskacceptans**.

Identifierade säkerhetsåtgärder och de risker som åtgärderna hanterar ska dokumenteras i en **åtgärdsplan** med ansvar och tidplan.

8. Kontinuitet, incidenter och krishantering

Organisationen ska planera för att kunna fortsätta verksamheten vid incidenter och kriser.

Det innebär bland annat krav kring:

- kontinuitet för informationsbehandling,
- prioriteringsordning för återställning,
- alternativa arbetssätt,
- redundanta funktioner,
- återställning av sektorskritiska system,
- incidenthantering,
- grundorsaksanalys,
- krisorganisation,
- kriskommunikation.

Alternativa arbetssätt och återställning av sektorskritiska system bör övas **minst en gång per år**. Även krishantering för sektorsverksamheten bör övas minst årligen.

9. Uppföljning och utvärdering

Organisationen ska kontrollera att säkerhetsåtgärderna faktiskt fungerar.

Det kan göras genom exempelvis:

- egenkontroller,
- mätningar,
- tester,
- interna revisioner,
- externa revisioner.

Säkerhetsåtgärder för **sektorskritiska system** ska följas upp och utvärderas vid behov men **minst en gång per år**.

10. Leverantörer och digitala leveranskedjor

MCFFS 2026:11 innehåller omfattande krav kopplade till leverantörer.

Innan ett system anskaffas eller informationsbehandling utkontrakteras ska organisationen analysera riskerna och bedöma om leverantören kan uppfylla säkerhetskraven under hela avtalstiden.

Organisationen behöver bland annat hantera:

- leverantörens säkerhetsåtgärder,
- underleverantörer,
- incidentrapportering från leverantören,
- sårbarheter,
- kontinuitet,
- uppföljning av leverantören,
- möjligheten att avsluta avtalet vid säkerhetsbrister,
- hantering av information när avtalet upphör.

Även äldre avtal ingångna före 1 oktober 2026 ska analyseras och, där det är möjligt och behövs, kompletteras med cybersäkerhetskrav.

11. Säker utveckling och systemlivscykel

Cybersäkerhet ska hanteras under systemens hela livscykel.

Vid utveckling och underhåll ska bland annat:

- informationsägare och systemägare involveras,
- informationsklassning finnas,
- riskanalys genomförs,
- åtgärdsplan hållas uppdaterad,
- etablerade metoder för säker utveckling användas.

Innan ett nytt system tas i produktion ska bland annat dokumentation, säkerhetstester, säkerhetsåtgärder och resurser vara hanterade.

Även avveckling ska ske kontrollerat och riskbaserat.

12. Dokumentation av den digitala miljön

Organisationen behöver ha en uppdaterad bild av sin digitala miljö.

Det omfattar exempelvis:

- system,
- hårdvara och mjukvara,
- versioner,
- nätverk och segment,
- informationsflöden,
- systemägare,
- informationsägare,
- leverantörer,
- sektorskritiska system,
- beroenden mellan system.

Föreskriften rekommenderar bland annat att arkitekturen visualiseras i en **systemkarta**.

13. Nätverkssegmentering

Den digitala miljön ska segmenteras för att begränsa konsekvenser och spridning av incidenter.

Organisationen behöver särskilt bedöma segmentering av exempelvis:

- användarklienter,
- administrativa klienter,
- sektorskritiska system,
- externa tjänster,
- gästnät,
- centrala säkerhetsfunktioner,
- leverantörsanslutningar,
- OT-system.

Utvecklings-, test- och utbildningsmiljöer ska också separeras från produktionsmiljön när de kan påverka säkerheten.

14. Säker konfiguration

System ska konfigureras för att försvåra obehörig åtkomst.

Det innebär bland annat att:

- standardkonton och förinställda autentiseringsuppgifter ska hanteras,
- onödiga funktioner ska stängas av eller tas bort,
- endast godkända informationsflöden ska tillåtas,
- behovet av application allowlisting ska bedömas,

- konfigurationer bör följas upp tekniskt.
-

15. Identitet, behörighet och MFA

Behörigheter ska följa principen om **minsta privilegium**.

Administrativa behörigheter ska tilldelas restriktivt och endast användas för administration.

Flerfaktorsautentisering ska bland annat användas för:

- åtkomst till IT-system med information i behov av utökat skydd,
- systemadministrativ åtkomst till IT-system,
- systemadministrativ åtkomst till OT-segment,
- personal och leverantörer som ansluter via externa nätverk.

Autentiseringsuppgifter från produktionsmiljön får inte återanvändas i utvecklings-, test- eller utbildningsmiljöer.

16. Övervakning och säkerhetsloggning

Organisationen ska kunna upptäcka tekniska fel, intrång och andra säkerhetsbrister.

Det innebär krav på bland annat:

- övervakning,
- larm,
- säkerhetsloggning,
- logganalys,
- skydd av loggar,
- hantering av sårbarhetsinformation.

Organisationen ska, om det inte är uppenbart obehövt, ansluta sig till NCSC:s automatiska notifieringar om tekniska sårbarheter, **ANTS**.

Behovet av bland annat realtidsövervakning och informationsutbyte via **MISP-SE** ska också bedömas.

17. Kryptering

Organisationen ska bedöma behovet av kryptering av information både vid lagring och överföring.

Säkerhetsloggar och autentiseringsuppgifter ska skyddas med kryptering vid överföring i den digitala miljön.

Information med utökat skyddsbehov, autentiseringsuppgifter och säkerhetsloggar ska krypteras när de överförs till system utanför den digitala miljön.

18. Säkerhetstester och sårbarhetshantering

Tekniska säkerhetsåtgärder ska verifieras genom säkerhetstester och granskningar.

För IT-system ska organisationen bland annat kontrollera:

- att system använder godkända versioner,
- att publicerade sårbarheter är hanterade,
- att avsedda säkerhetskfigurationer faktiskt är implementerade.

Det innebär att regelbunden vulnerability scanning och andra tekniska säkerhetstester blir viktiga komponenter i organisationens kontrollmiljö.

19. Backup och återställning

Organisationen ska kunna återställa information inom fastställda acceptabla tider.

Backupstrategin bör bland annat definiera:

- vilken information som säkerhetskopieras,
- hur ofta backup tas,
- hur backup verifieras,
- hur länge kopior sparas,
- hur de skyddas,
- hur återläsning genomförs och verifieras.

Minst en säkerhetskopia bör dessutom skyddas mot skadlig kod genom separation från systemet som informationen kommer från.

20. Intrångsdetektering och intrångsskydd

För IT-segment i produktionsmiljön ska organisationen använda **intrångsdetektering och intrångsskydd**.

För OT samt utvecklings-, test- och utbildningsmiljöer ska behovet analyseras och hanteras.

21. Ändrings- och patchhantering

Ändringar i produktionsmiljön ska hanteras **strukturerat och spårbart**.

För IT-system ska säkerhetsuppdateringar genomföras skyndsamt. System som inte längre får säkerhetsuppdateringar från leverantören ska bytas ut eller uppgraderas utan onödigt dröjsmål.

I de allmänna råden anges att arbetet med att införa en säkerhetsuppdatering bör påbörjas **inom 72 timmar** från det att skyddande programvara har tillgängliggjorts.

22. Fysisk säkerhet

MCFFS 2026:11 omfattar även fysisk säkerhet.

Organisationen behöver bland annat hantera:

- tillträdeskontroll,
- identitetskontroll,
- server- och kommunikationsutrymmen,
- fysisk övervakning och larm,
- brand,
- vatten,
- temperatur och luftfuktighet.

Organisationen ska även säkerställa tillräcklig funktion hos exempelvis:

- el,
- kyla,
- värme,
- ventilation,
- externa kommunikationsnät och kommunikationstjänster.

Behovet av redundans ska analyseras.

23. Särskilda krav för offentlig förvaltning

För offentlig förvaltning finns dessutom sektorsspecifika krav på system för **kriskommunikation**.

Organisationen ska kontrollera cybersäkerheten i system som används för samverkan samt intern och extern kriskommunikation.

Behovet av att använda exempelvis **Raket/SWEN** och **SGSI** ska också analyseras.

Checklista inför 1 oktober 2026

Område	Kontrollfråga
Ledning	Har ledningen fått relevant NIS2/cybersäkerhetsutbildning?
Governance	Finns mål, ansvar, mandat och resurser?
Risk	Finns aktuella informationsklassningar och riskanalyser?
Evidens	Kan genomförda säkerhetsåtgärder bevisas?
Kontinuitet	Finns och övas kontinuitets- och återställningsplaner?
Incident	Finns fungerande incident- och krishantering?
Leverantörer	Har kritiska leverantörer och avtal granskats?
Asset Management	Finns aktuell system-, hårdvaru- och mjukvaruinventering?
IAM	Är least privilege och MFA implementerat där det krävs?
Network Security	Finns ändamålsenlig segmentering?
Monitoring	Finns övervakning, loggning och logganalys?
Vulnerabilities	Finns systematisk scanning och sårbarhetshantering?
Patchning	Kan organisationen hantera kritiska uppdateringar skyndsamt?
Backup	Är backup och återställning testad?
Fysisk säkerhet	Är lokaler och kritisk infrastruktur tillräckligt skyddade?
Assurance	Följs säkerhetsåtgärdernas effektivitet upp regelbundet?

Läs originalföreskriften

[NCSC/FRA – MCFES 2026:11](#)